

Security for e-Government

Wednesday, November 5, 2025 11:20 AM

Security for E-Government

E-government is becoming very important worldwide. To provide trusted online services, e-governance must focus on being **effective, efficient, and flexible**. Citizens get maximum benefit if e-services have these features:

- Users know what services are available.
Example: A government website lists services like online tax filing, passport applications, or birth certificate requests.
- Users understand the benefits.
Example: Online tax filing saves time and avoids queues.
- Services are accessible to everyone in the target group.
Example: Websites should work on phones and computers, including people with disabilities.
- Users can find services easily.
Example: A search bar helps locate forms or applications quickly.

Information Security: CIA Triad

Information security in e-government is measured by three main principles:

1. **Confidentiality** – Protecting sensitive info from unauthorized access.
Example: Only authorized staff can view your tax records.
2. **Integrity** – Ensuring data is accurate and complete.
Example: Your driving license info cannot be changed by someone else.
3. **Availability** – Making sure information and services are accessible when needed.
Example: The online passport application system works 24/7.

Types of E-Government Services

1. **Publishing:** Posting information online.
Example: Government publishes traffic rules on a website.
2. **Interactive Processing:** Citizens read instructions and submit forms online.
Example: Filling an online complaint form.
3. **Transaction Processing:** Information submitted online is processed for official purposes.
Example: Filing taxes or renewing a driver's license.
4. **Service Delivery:** Actual execution of approved requests.
Example: Issuing a digital driving license after online renewal.

Challenges in E-Government Security

Threats can be **accidental or deliberate**:

- **Accidental/Natural:** Floods, fires, storms, human error.
- **Deliberate:** Fraud, hacking, viruses, info theft.

The **CIA Triad (Confidentiality, Integrity, Availability)** guides security policies.

1) Availability

Ensures that info and IT services are accessible when needed.

- **Fault-related concerns:** Hardware failure, program errors, or non-computer system failures.
Example: Server crash stops citizens from filing taxes online.
- **Intrinsic concerns:** Problems with storage, magnetic media failure, or physical damage.
Example: Fire damages servers storing government data.
- **Denial of Service (DoS) attacks:** Hackers make services unavailable.
Example: An attacker overloads a government website, making it crash.

2) Integrity

Ensures that information is accurate and not tampered with.

- **Data Content Integrity Issues:** Unauthorized changes to published info or submitted applications.
Example: Someone illegally edits online land records.
- **Intentional modification of data:** Hackers bypass login systems and change data.
Example: Changing voter registration details on the government portal.
- **Connection Integrity Issues:** Users must trust that the information comes from the government and reaches the correct destination.
Example: Your online tax form goes to the tax department, not a hacker.

3) Confidentiality

Protecting sensitive info from being seen by unauthorized people.

- **Consequences of breach:** Depends on what info is exposed.
Example: Public exposure of citizens' financial data.
- **Loss of trust:** If sensitive info is leaked, citizens may lose confidence in e-government services.
Example: A leak of online health records reduces trust in government websites.

Security Approaches for E-Government

1. Cryptographic Mechanisms

- **What it is:** Cryptography hides information so no one can read it without permission. It turns the original message into unreadable code called *ciphertext*.
- **Examples of methods:** AES, DES, RSA with encryption sizes like 16-bit, 32-bit, 128-bit, 256-bit.
- **Example:** When you submit your income tax online, encryption ensures hackers cannot read your personal financial details.

2. Database Design

- **What it is:** Proper database design protects private data. Some government services handle sensitive info that must follow privacy laws.
- **Example:** A health ministry database ensures only authorized staff can see patient data, even if multiple departments use the same system.

3. Anti-virus Systems

- **What it is:** Software that protects computers from viruses that can delete or corrupt data.
- **Example:** Installing antivirus on government office computers prevents malware from destroying citizen records.

4. Firewalls

- **What it is:** A security system that blocks unauthorized access to a network. It can be hardware, software, or both.
- **Techniques:** Packet filtering, application gateways, proxy servers.
- **Example:** A firewall in a government server prevents hackers from accessing citizen data.

5. Analyst Tools

- **What it is:** Tools used by security experts to detect system weaknesses or attacks.
- **Example:** Tools that check a government portal for bugs that could let attackers steal information.

6. Monitoring Tools

- **What it is:** Regularly checks network activity to detect unusual or suspicious actions. Alerts administrators if something is wrong.
- **Example:** Monitoring software notices if someone tries to repeatedly log in with wrong passwords and alerts IT staff.

7. Biometric Technology

- **What it is:** Identifies or verifies people based on physical or behavioral traits.
- **Physical traits:** Fingerprint, iris scan, face recognition.

- **Behavioral traits:** Typing pattern, signature, voice.
- **Example:** Using fingerprint verification to log into an online government service ensures only the authorized person accesses it.

Security Management Model

- **Definition:** A framework that explains what an organization should do to protect itself from security threats.
- **Key point:** It tells *what needs to be done* but not *how*, which makes it flexible for different types of organizations.
- **Characteristics:** Should be **flexible, scalable, robust, and detailed** enough to guide security practices.
- **Example:** A government department follows a model that defines rules for secure data storage, access, and monitoring, but can choose specific software or methods depending on its resources.

Access Control Models

- **Purpose:** Access control decides who can access which resources (both physical and digital).
- **Main processes:**
 1. **Identification:** The user claims an identity (e.g., username, ID card).
 2. **Authentication:** The system checks if the user is really who they claim to be (e.g., password, fingerprint, OTP).
 3. **Authorization:** The system grants permission to access certain files or areas (e.g., only HR staff can access employee salary records).
 4. **Accountability:** The system keeps a record of user actions for auditing and accountability.
- **Example:** In an online tax portal, only registered tax officers can approve returns, while citizens can only view or submit their own tax information.

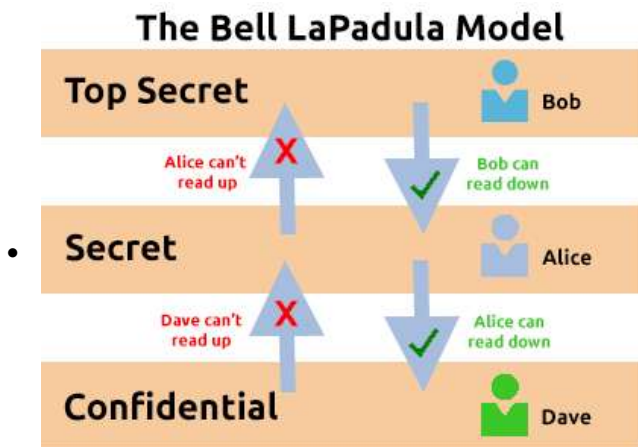
Security Architecture Models

- **Definition:** A design framework showing how security policies, mechanisms, and services are implemented.
- **Key point:** Can include software, hardware, rules, and practices. Helps organizations identify weaknesses and improve security.
- **Example:** A government e-portal uses firewalls, encrypted connections, and access policies to protect citizen data.

Specific Security Models

1. Bell-LaPadula Confidentiality Model

- **Focus:** Keeps data secret (confidentiality).
- **How it works:** Multilevel security system where information can only flow *upward* (from low-level to high-level security) but not downward.
- **Example:** Classified government documents are only readable by officers with the required clearance; lower-level employees cannot access them.



2. Biba Integrity Model

- **Focus:** Protects the accuracy and correctness of data (integrity).

How it works:

- **No Write Up (NWU):** A user cannot write data to a **higher integrity level**. This prevents low-integrity users from contaminating high-integrity data.
- **No Read Down (NRD):** A user cannot read data from a **lower integrity level**. This prevents users from using untrustworthy or corrupted data.

Integrity Levels: Data and users are assigned **integrity levels** like High, Medium, Low.

- **Example:** In a hospital system, a nurse cannot change the verified medical records approved by a doctor.

3. Clark-Wilson Model

Focus: Protects **data integrity** by enforcing well-formed transactions and separation of duties. It ensures that only authorized users can make changes to data in controlled ways.

How it works:

- Uses **triple rules** called **subject–program–object**:
 - **Subject:** The user (e.g., government officer, accountant)
 - **Program:** The application or transaction (e.g., tax filing software, payroll system)
 - **Object:** The data being accessed or modified (e.g., citizen tax records, salary data)
- Users **cannot directly modify data**. They must use authorized programs (well-formed transactions).
- Ensures **separation of duties**, meaning no single user can perform conflicting actions that might compromise data integrity.

Example:

Imagine an online government payroll system:

- **Data (Object):** Employee salaries
- **Program (Transaction):** Payroll software
- **User (Subject):** HR staff

Rules:

1. **HR staff cannot directly change salary numbers** in the database.
2. They must use the payroll software to process updates.
3. The system logs all transactions for accountability.
4. A single user cannot both approve and process a salary payment — approval and processing are separate roles.

Result:

- Prevents accidental or malicious modification of salaries.
- Maintains integrity of the payroll system.
- Ensures traceability of actions for auditing.

4. Graham-Denning Model

Focus:

- Manages **how subjects (users) and objects (data/resources) are securely created, deleted, and accessed** in a system.
- Primarily used in **distributed systems** for controlling access.

Components:

1. **Subjects:** Entities (users, processes) that can perform actions.
2. **Objects:** Resources (files, databases, programs) to be accessed or manipulated.
3. **Access Rights Rules:** A set of 8 rules that define how subjects and objects interact.

Eight Rules (Simplified):

1. Create an object.
2. Delete an object.
3. Create a subject.
4. Delete a subject.
5. Read access: Grant read rights to a subject.
6. Write access: Grant write rights to a subject.
7. Grant access: Give another subject access to an object.
8. Revoke access: Remove access rights from a subject.

Example:

- **Scenario:** A university system.
 - **Subjects:** Students, Professors, Admin Staff
 - **Objects:** Student records, grade files, exam schedules
 - **Rules in action:**
 - Admin staff can **create** new student records.
 - Professors can **write** grades but cannot delete student records.
 - Students can **read** their own records but cannot access others'.
 - Admin can **grant or revoke** access if a staff member leaves.

5. Harrison-Ruzzo-Ullman (HRU) Model

Focus:

- Provides a **flexible access control system** using an access matrix.
- Allows dynamic management of rights in complex systems.

Components:

1. **Subjects:** Users or processes.
2. **Objects:** Resources like files, databases, or programs.
3. **Access Rights:** Permissions such as read, write, execute.
4. **Access Matrix:** A table where rows = subjects, columns = objects, and each cell lists the access rights of that subject for that object.

How it works:

- The access matrix shows exactly what each subject can do with each object.
- Rights can be added or revoked as needed, keeping control flexible.
- Helps enforce security policies while allowing changes over time.

Example:

- **Scenario:** Corporate system.
 - **Subjects:** Employees (Alice, Bob)
 - **Objects:** Project files, payroll records
 - **Access Matrix:**

	• Project File	• Payroll Record
• Alice	• Read, Write	• None
• Bob	• Read	• Read
- Alice can update project files but cannot see payroll; Bob can view payroll but not edit project files.
- Admin can **update matrix** to grant or revoke rights as roles change.

6. Brewer-Nash Model (Chinese Wall)

Focus:

- Prevents **conflict of interest** in organizations, especially in commercial systems.
- Access permissions change dynamically based on user actions.

How it works:

- Users can access information in one company or project but cannot access data from a competing company once they have accessed the first.
- Ensures confidentiality while allowing dynamic work in multi-client environments.

Example:

- **Scenario:** Consulting firm with multiple clients (Client A and Client B are competitors).
 - A consultant reads Client A's financial data.
 - The model **blocks access** to Client B's data to prevent conflict of interest.
- However, the consultant can continue accessing different projects for Client A.

E-Government Security Architecture

Definition:

- The security architecture is a **high-level plan** that sets security goals for an e-governance project.
- It describes the rules and procedures that **all users, owners, and operators** of e-governance systems must follow.
- It ensures **legal protection, privacy, and safety** of digital services, citizens' information, and public order.

Purpose:

- Provide systematic and long-term security.
- Give legal status to digital data protection.
- Protect privacy of individuals and secure public digital services like auctions or online records.

Example:

- When citizens submit online applications for passports, the system ensures that **only authorized government officers can access the data**, it is stored securely, and any online transactions are legally protected.



Fig. 1 E-governance Security Architecture

E-Government Security Architecture Reference Framework

- This framework is part of the **Technical Reference Model (TRM)**.
- TRM provides a foundation to **standardize technology, security, and service components** used in e-governance.

Hierarchy in TRM:

1. Service Area:

- Groups related standards and technologies for a broad area of service.
- Example: "Citizen Services" could be a service area, which includes issuing ID cards, online payments, and passport applications.

2. Service Category:

- Breaks each service area into smaller groups based on function or business purpose.
- Example: Within “Citizen Services,” one category could be “Online Payments,” another could be “Document Verification.”

3. Service Standards:

- Defines the specific technologies and standards that support each service category.
- Example: Online Payments category may use **SSL encryption** for secure transactions, **two-factor authentication** for user login, and **audit logs** for tracking transactions.

Contribution:

- Helps public institutions **map their technology and security practices** to a standard reference.
- Ensures consistency, reliability, and reuse of security measures across different e-governance projects.

Security Standards

A security standard is a set of rules or requirements that a system or product must meet to be considered secure. Following these standards ensures the system is safe, reliable, and efficient.

Why they are important:

- Standards allow **comparison** of security across different systems.
- They ensure **quality, safety, reliability, and efficiency** at reasonable cost.
- Organizations can adopt **international best practices** to protect business processes and satisfy legal or customer requirements.

Examples of Security Standards:

1. ISO/IEC 27000 Series

- Developed by ISO and IEC.
- Focus: Information security management, risk handling, and controls.
- Example: A government agency uses ISO 27001 to ensure its citizen database is secure and all staff follow security policies.

2. NIST SP800 Series

- Developed by the National Institute of Standards and Technology (NIST).
- Oldest and most detailed set of standards for information security.
- Example: A university follows SP800-53 guidelines to protect online student records from unauthorized access.

3. ISF Standard of Good Practice (SoGP)

- Developed by the Information Security Forum.
- Provides detailed best practices for securing information.
- Example: A bank implements ISF SoGP recommendations to protect customer financial data and prevent breaches.

4. COBIT (Control Objectives for Information and Related Technology)

- Developed by ISACA and IT Governance Institute.
- Focus: Best practices for IT governance and management.
- Example: A government IT department uses COBIT to ensure IT operations are aligned with policies, risks are managed, and audits can be performed efficiently.